

JWT

Let us look at what is inside the JSON Web token (JWT). The access token anatomy looks like what is shown in Figure 3.

In case it is found that the JWT token is stolen or compromised, the server can be notified of this incident and it can blacklist the token. Figure 4 gives the sequence diagram of how this works.

Takeaway

When we loosely say ‘auth’, it indicates two completely orthogonal but correlated things—the authentication and the authorisation. In this article,

we talked about the latter using the industry standard OAuth2 mechanism. The idea behind OAuth2 is the delegation of authorisation using an independent authorisation server or microservice. An application, in lieu of the user, asks for authorisation permission from the authorisation server in two steps: the authorisation token, followed by the access token. The access

token has three layers of security — the secret key that is never passed out of the authorisation server, the token that comes with a predefined expiry stored securely in the application, and the application to resource server which is SSL/TSL encrypted. In this way, OAuth2 ensures airtight and invincible security, making it a widely accepted and adopted framework for authorisation. **END** 

By: Pradip Mukhopadhyay

The author has 20 years of experience across the stack — from low level system programming to high level GUI. He is a FOSS enthusiast and is currently working at NetApp, Bengaluru.

support@efy.in

**Do you have a query,
suggestion or a complaint?**

**You can e-mail it to
support@efy.in
and we will take care
of the rest.**



electronics
FOR YOU
www.electronicshobby.com

OpenSource
THE COMPLETE MAGAZINE ON OPEN SOURCE
FOR YOU
www.opensourceforu.com

EFY GROUP
YOURS SINCE 1969
www.efy.in